

SYS.1.11 Server unter FreeBSD

1 Beschreibung

1.1 Einleitung

FreeBSD ist ein freies, Unix-derivates Betriebssystem, das auf den Einsatz in hochperformanten Netzwerk- und Serverumgebungen ausgelegt ist. Zu seinen zentralen Architekturmerkmalen gehören das leistungsfähige Dateisystem ZFS, das ressourcenschonende Virtualisierungssystem „Jails“ zur Isolation von Prozessen sowie eine strikte strukturelle Trennung zwischen dem Kern-Betriebssystem (Basissystem) und Drittanbieter-Software (Ports/Packages).

Aufgrund dieser spezifischen Architekturkonzepte weichen die Administrations- und Sicherheitsmechanismen von FreeBSD von anderen Unix-artigen Systemen ab. Dies erfordert angepasste Strategien, um Systemdienste, Netzwerke und Datenablagen sicher zu betreiben.

1.2 Zielsetzung

Der Baustein beschreibt die Anforderungen für die sichere Planung, Installation, Konfiguration und den laufenden Betrieb von Servern unter dem Betriebssystem FreeBSD. Ziel ist es, die systemspezifischen Sicherheitsfunktionen – insbesondere Jails, ZFS und hostbasierte Paketfilter – so zu konfigurieren, dass Vertraulichkeit, Integrität und Verfügbarkeit der verarbeiteten Daten und bereitgestellten Dienste dauerhaft gewährleistet sind.

1.3 Abgrenzung und Modellierung

Der Baustein SYS.1.11 ist auf alle IT-Systeme anzuwenden, auf denen das Betriebssystem FreeBSD installiert wird und die Server-Aufgaben übernehmen.

Dieser Baustein bündelt spezifische Aspekte von FreeBSD. Allgemeine Sicherheitsanforderungen an Serversysteme werden in diesem Baustein nicht vollständig wiederholt; diese sind im Baustein SYS.1.1 *Allgemeiner Server* geregelt, der zwingend mitanzuwenden ist. Für den übergreifenden IT-Betrieb ist der Baustein OPS.1.1.1 *Allgemeiner IT-Betrieb* umzusetzen.

Werden für die Isolation von Diensten Jails genutzt, müssen zusätzlich die konzeptionellen Vorgaben aus SYS.1.6 *Containerisierung* berücksichtigt werden. Werden komplexe ZFS-Speicherpools für Speicherdienste bereitgestellt, sind die ergänzenden Anforderungen aus SYS.1.8 *Speicherlösungen* heranzuziehen.

2 Gefährdungslage

Für den Betrieb von FreeBSD-Servern sind folgende spezifische Gefährdungen von besonderer

Bedeutung:

Ausbruch aus FreeBSD-Jails

Die Isolation von Diensten mittels Jails soll verhindern, dass kompromittierte Prozesse auf das Host-System zugreifen. Eine fehlerhafte Konfiguration (z. B. eine zu hohe Freigabe von Zugriffsrechten, ein unsicheres Devfs-Ruleset oder Schwachstellen im Kernel) kann es einem Angreifer ermöglichen, diese Isolation zu durchbrechen, das Host-System zu kompromittieren und sich weitreichende Privilegien zu verschaffen.

Kompromittierung durch unsichere Drittanbieter-Pakete

Über das Ports- und Paketsystem (pkg) lässt sich Drittanbieter-Software auf FreeBSD installieren. Wird Software aus nicht vertrauenswürdigen Quellen kompiliert oder werden bekannte Schwachstellen in installierten Paketen nicht zeitnah gepatcht, können Angreifer diese Lücken nutzen, um Schadcode auf dem System auszuführen.

Fehlkonfiguration spezifischer Systemkomponenten

Das ZFS-Dateisystem und der FreeBSD-Netzwerk-Stack bieten mächtige Funktionen. Eine unsachgemäße Konfiguration, etwa eine fehlerhafte Strukturierung von ZFS-Datasets, eine unverschlüsselte Replikation über ungeschützte Netze oder ein Verzicht auf Snapshots, kann bei Hardwarefehlern oder Ransomware-Angriffen zu signifikantem Datenverlust führen.

Denial-of-Service durch unsachgemäßes System-Tuning

FreeBSD ermöglicht die weitreichende Anpassung von Kernel-Parametern (sysctl) und Ressourcenlimits. Werden diese Werte ohne tiefgehendes Verständnis oder mit unzureichenden Restriktionen konfiguriert, können Angreifer Ressourcen (wie RAM, CPU oder File Deskriptoren) gezielt erschöpfen, was zum Ausfall der bereitgestellten Dienste führt.

Ausnutzung von Schwachstellen in Basissystem und Paketen

Da in FreeBSD das Basissystem und die installierten Pakete getrennt voneinander aktualisiert werden, besteht die Gefahr, dass Administrierende nur einen der beiden Update-Pfade bedienen. Bleibt das Basissystem auf einem veralteten Stand, bleiben tiefliegende Schwachstellen bestehen, die für Privilege-Escalation-Angriffe ausgenutzt werden können.

3 Anforderungen

Im Folgenden sind die spezifischen Anforderungen des Bausteins SYS.1.11 aufgeführt. Grundsätzlich ist der IT-Betrieb für die Erfüllung der Anforderungen zuständig. Abweichungen werden in den entsprechenden Anforderungen gesondert genannt.

Zuständigkeiten	Rollen
-----------------	--------

Grundsätzlich zuständig	IT-Betrieb
Weitere Zuständigkeiten	Fachverantwortliche

3.1 Basis-Anforderungen

Die folgenden Anforderungen MÜSSEN vorrangig erfüllt werden.

SYS.1.11.A1 Planung des Server-Betriebs unter FreeBSD (B)

Vor der Installation MUSS geplant werden, wie der FreeBSD-Server in die bestehende Infrastruktur integriert werden soll. Es MUSS festgelegt werden, welche Systemdienste benötigt werden und wie das Dateisystem sowie die Netzwerkanbindung strukturiert sein müssen. Die Planung MUSS dokumentiert werden.

SYS.1.11.A2 Gesicherte und minimalistische Installation (B)

Die Installation von FreeBSD MUSS von einem kryptografisch verifizierten, offiziellen Installationsmedium erfolgen. Es DÜRFEN nur die für den Betrieb zwingend erforderlichen Komponenten (Distribution Sets) des Basissystems installiert werden. Für das Administrator-Konto (root) MUSS ein sicheres Passwort vergeben werden.

SYS.1.11.A3 Deaktivierung nicht benötigter Dienste (B)

Das System MUSS so konfiguriert werden, dass keine ungenutzten Dienste gestartet werden. Alle Dienste, die standardmäßig aktiviert sind, aber für den spezifischen Betriebszweck nicht benötigt werden, MÜSSEN in der Konfiguration (z. B. /etc/rc.conf) dauerhaft deaktiviert werden.

SYS.1.11.A4 Konsequentes Patch-Management für Basissystem und Pakete (B)

Sowohl das Basissystem als auch alle installierten Drittanbieter-Pakete MÜSSEN zeitnah aktualisiert werden. Hierfür MÜSSEN die systemeigenen Werkzeuge (z. B. freebsd-update, pkg) verwendet werden. Zusätzlich MUSS das System regelmäßig und automatisiert auf bekannte Schwachstellen in installierten Paketen geprüft werden (z. B. mittels pkg audit).

SYS.1.11.A5 Konfiguration der systemeigenen Firewall (B)

Es MUSS eine in FreeBSD integrierte Firewall (z. B. PF oder IPFW) aktiviert werden. Diese MUSS mit einer restriktiven „Default Deny“-Regelbasis konfiguriert werden, die standardmäßig alle nicht explizit freigegebenen ein- und ausgehenden Verbindungen blockiert.

SYS.1.11.A6 Absicherung des administrativen Zugriffs (B)

Der Remote-Zugriff für Administrationszwecke (z. B. über SSH) MUSS kryptografisch abgesichert sein. Es DARF NICHT möglich sein, sich remote direkt mit dem Konto root

anzumelden.

3.2 Standard-Anforderungen

Gemeinsam mit den Basis-Anforderungen entsprechen die folgenden Anforderungen dem Stand der Technik bei normalem Schutzbedarf. Sie SOLLTEN grundsätzlich erfüllt werden.

SYS.1.11.A7 Konzept für Jails und ZFS (S)

Es SOLLTE ein Konzept zur Nutzung der spezifischen FreeBSD-Funktionen erstellt werden. Insbesondere SOLLTE vorab geplant werden, welche Dienste zur Isolation in Jails ausgelagert werden und wie die Datasets im ZFS-Dateisystem strukturiert sein müssen, um Datensicherung und Berechtigungsmanagement optimal zu unterstützen.

SYS.1.11.A8 Isolation von Diensten mittels Jails (S)

Netzwerkdienste SOLLTEN voneinander sowie vom Basissystem isoliert betrieben werden. Hierfür SOLLTEN die Dienste in dedizierte FreeBSD-Jails ausgelagert werden. Den Jails SOLLTEN nur die Berechtigungen zugewiesen werden, die für den jeweiligen Dienst zwingend erforderlich sind.

SYS.1.11.A9 Strukturierte Nutzung und Sicherung von ZFS-Dateisystemen (S)

Das ZFS-Dateisystem SOLLTE verwendet werden, um Daten logisch in separaten Datasets zu strukturieren (z. B. getrennt nach System, Jails, Logs und Benutzerdaten). Es SOLLTEN regelmäßig automatisiert Snapshots der kritischen Datasets erstellt werden, um eine schnelle Wiederherstellung nach Datenverlust oder Fehlkonfigurationen zu gewährleisten.

SYS.1.11.A10 Härtung des Kernels über System-Parameter (S)

Sicherheitsrelevante Kernel-Parameter SOLLTEN restriktiv konfiguriert werden (z. B. über `sysctl.conf`). Dies SOLLTE Maßnahmen umfassen, um das System vor gängigen Netzwerkangriffen zu schützen (z. B. Schutz vor SYN-Flooding) und den Informationsabfluss auf Systemebene (z. B. Ausblenden von Prozessinformationen fremder Benutzer) einzuschränken.

SYS.1.11.A11 Konfiguration von Ressourcenlimits (S)

Um Denial-of-Service-Angriffe durch Ressourcenerschöpfung zu erschweren, SOLLTEN dedizierte Ressourcenlimits konfiguriert werden. Dies SOLLTE auf Benutzerebene (z. B. über `login.conf`) sowie für isolierte Prozesse und Jails (z. B. über das Resource Control Framework `rctl`) erfolgen.

SYS.1.11.A12 Zentrale Protokollierung von Systemereignissen (S)

Der systemeigene Protokollierungsdienst SOLLTE so konfiguriert werden, dass

sicherheitsrelevante Ereignisse des Hosts und der betriebenen Jails zentral erfasst werden. Die Logdaten SOLLTEN zeitnah an ein separates Log-Management- oder SIEM-System weitergeleitet werden.

3.3 Anforderungen bei erhöhtem Schutzbedarf

Die folgenden Anforderungen sind exemplarisch und bei erhöhtem Schutzbedarf zu berücksichtigen; die konkrete Festlegung erfolgt im Rahmen einer Risikoanalyse. Der Schutzziel-Bezug ist am Ende jeder Anforderung in Klammern angegeben (C = Vertraulichkeit, I = Integrität, A = Verfügbarkeit).

SYS.1.11.A13 Einsatz von ZFS-Verschlüsselung (H)

Datasets auf ZFS, die sensible Daten enthalten, SOLLTEN mit der nativen Verschlüsselungsfunktion von ZFS verschlüsselt werden. Die Schlüsselmaterialien SOLLTEN sicher verwaltet werden. (C, I)

SYS.1.11.A14 Erweiterte Härtung von Jails (H)

Jails SOLLTEN zusätzlich gehärtet werden. Hierbei SOLLTEN Berechtigungen über restriktive Parameter (z. B. securelevel) minimiert und der Zugriff auf Gerätedateien über strikte Devfs-Rulesets streng limitiert werden. (C, I, A)

SYS.1.11.A15 Absicherung des Boot-Prozesses (H)

Sofern die zugrunde liegende Hardware dies unterstützt, SOLLTE der UEFI Secure Boot Mechanismus von FreeBSD genutzt werden, um sicherzustellen, dass beim Start ausschließlich ein kryptografisch signierter Bootloader und Kernel ausgeführt wird. (I)

SYS.1.11.A16 Einsatz des Mandatory Access Control (MAC) Frameworks (H)

Das in FreeBSD integrierte Mandatory Access Control (MAC) Framework SOLLTE aktiviert werden. Es SOLLTE ein geeignetes Sicherheitsrichtlinienmodul (z. B. mac_bsdextended) konfiguriert werden, um die Zugriffsrechte von Prozessen und Benutzern feingranular und jenseits klassischer Unix-Rechte zu steuern. (C, I)

SYS.1.11.A17 Erstellung eines gehärteten, angepassten Kernels (H)

Für hochkritische Systeme SOLLTE ein angepasster Kernel kompiliert werden, aus dem alle für den spezifischen Einsatzzweck nicht benötigten Treiber, Protokolle und Funktionen entfernt wurden, um die Angriffsfläche auf Kernel-Ebene auf ein Minimum zu reduzieren. (C, I, A)

4 Weiterführende Informationen

4.1 Wissenswertes

Das FreeBSD-Projekt stellt mit dem offiziellen "FreeBSD Handbook" eine sehr ausführliche, stets aktuelle Dokumentation bereit, die umfangreiche Kapitel zu Systemsicherheit, Jails, Firewalls (PF/IPFW) und ZFS beinhaltet. Das Handbuch ist die primäre Referenz für die administrative Absicherung von FreeBSD-Systemen.

Weitere Anhaltspunkte für das sichere Konfigurieren von Systemdiensten auf Unix-Derivaten bieten die Härtungs-Leitfäden des Center for Internet Security (CIS Benchmarks), auch wenn diese sich primär auf Linux-Derivate fokussieren, lassen sich die architektonischen Schutzprinzipien übertragen.

Kreuzreferenztable zu elementaren Gefährdungen

Die folgenden elementaren Gefährdungen sind für den Baustein SYS.1.11 von Bedeutung.

- G 0.18 Fehlplanung oder fehlende Anpassung
- G 0.19 Offenlegung schützenswerter Informationen
- G 0.20 Informationen oder Produkte aus unzuverlässiger Quelle
- G 0.23 Unbefugtes Eindringen in IT-Systeme
- G 0.25 Ausfall von Geräten oder Systemen
- G 0.27 Ressourcenmangel
- G 0.28 Software-Schwachstellen oder -Fehler
- G 0.30 Unberechtigte Nutzung oder Administration von Geräten und Systemen
- G 0.31 Fehlerhafte Nutzung oder Administration von Geräten und Systemen
- G 0.39 Schadprogramme
- G 0.40 Verhinderung von Diensten (Denial of Service)
- G 0.45 Datenverlust

Anforderung	G 0.18	G 0.19	G 0.20	G 0.23	G 0.25	G 0.27	G 0.28	G 0.30	G 0.31	G 0.39	G 0.40	G 0.45
SY S.1.11. A1 (B)	X											
SY S.1.11. A2 (B)			X	X						X		

SY S.1 .11. A3 (B)				X			X				X	
SY S.1 .11. A4 (B)			X	X			X			X		
SY S.1 .11. A5 (B)				X				X		X	X	
SY S.1 .11. A6 (B)		X		X				X				
SY S.1 .11. A7 (S)	X								X			
SY S.1 .11. A8 (S)				X			X	X		X		
SY S.1 .11. A9 (S)					X				X			X
SY		X		X							X	

S.1 .11. A1 0 (S)												
SY S.1 .11. A1 1 (S)						X					X	
SY S.1 .11. A1 2 (S)				X				X				
SY S.1 .11. A1 3 (H)		X										
SY S.1 .11. A1 4 (H)				X				X		X		
SY S.1 .11. A1 5 (H)				X						X		
SY S.1		X		X				X				

.11. A1 6 (H)												
SY S.1 .11. A1 7 (H)				X			X			X		